

Table des matières ↑

- [DAT Vue Composants & Analyse de Sécurité - SIREINES](#)
 - [1. Vue Composants \(C4-L3\) - Architecture Interne Détaillée](#)
 - [1.1 Diagramme de composants global](#)
 - [1.2 Fiches composants détaillées](#)
 - [COMP-001 : DossierRechercheMotsClefsAction](#)
 - [Interfaces exposées](#)
 - [Dépendances internes](#)
 - [Dépendances externes](#)
 - [□ Vulnérabilités critiques identifiées](#)
 - [Dette technique](#)
 - [COMP-002 : ExtractionsServicesImpl](#)
 - [□ Vulnérabilités critiques identifiées](#)
 - [Dette technique - □ Critique](#)
 - [COMP-003 : ImportsServicesImpl](#)
 - [□ Vulnérabilités critiques identifiées](#)
 - [COMP-004 : CerbereUtil + SireinesSessionFilter](#)
 - [Dépendances externes critiques](#)
 - [□ Vulnérabilités identifiées](#)
 - [COMP-005 : ESEmbeddedSearchServicesPlugin](#)
 - [□ Vulnérabilités critiques](#)
 - [2. Matrice de vulnérabilités STRIDE](#)
 - [3. Inventaire des dépendances et vulnérabilités](#)
 - [3.1 Dépendances Maven \(pom.xml sireines-web\)](#)
 - [3.2 Dépendances Frontend \(analyse templates\)](#)
 - [4. Dettes techniques identifiées](#)
 - [5. Recommandations de sécurité prioritaires](#)
 - [5.1 Court terme \(0-3 mois\) - □ Urgent](#)
 - [5.2 Moyen terme \(3-12 mois\) - □ Important](#)
 - [5.3 Long terme \(> 12 mois\) - □ Stratégique](#)
 - [6. Schéma de flux de données sécurisé \(DFD\)](#)
 - [7. Checklist OWASP Top 10 2021 - Mapping complet](#)
 - [8. Plan d'action sécurité synthétique](#)
 - [9. Annexes](#)
 - [9.1 Glossaire sécurité](#)
 - [9.2 Références CVE critiques à surveiller](#)

DAT Vue Composants & Analyse de Sécurité - SIREINES ↑

Version : 2.5.12 **Date d'analyse** : 23 février 2026 **Classification** : Interne - Contient informations de vulnérabilité

1. Vue Composants (C4-L3) - Architecture Interne Détaillée ↑

1.1 Diagramme de composants global ↑

1.2 Fiches composants détaillées ↑

COMP-001 : DossierRechercheMotsClefsAction ↑

Attribut	Valeur
Responsabilité	Recherche avancée de dossiers par mots-clés avec autocomplétion et filtres facettes
Technologie	Java 7, Struts 2.5.x, Vertigo Dynamo
Package	i2.application.sireines.controller.dossiers
Type	Action Struts (Controller)
Taille	8 786 octets (classe complexe)

Interfaces exposées ↑

Méthode	Entrée	Sortie	Description
doSearch()	Formulaire recherche (mots-clés, filtres)	Liste dossiers paginée	Recherche principale
loadFacets()	Critères de recherche	Facettes dynamiques	Filtrage par thésaurus
autocomplete()	Fragment texte	Suggestions mots-clés	Autocomplétion AJAX

Dépendances internes ↑

- DossiersServices (service métier)
- DossierMotsClefsSearchLoader (loader spécialisé)
- AbstractSireinesFacetActionSupport (classe parent)

Dépendances externes ↑

Librairie	Version	Usage	Statut sécurité
Struts 2	2.5.x	MVC, injection dépendances	☐ CVE récurrentes
Vertigo Dynamo	-	ORM, recherche facettée	☐ Interne
Elasticsearch	7.x (embedded)	Indexation full-text	☐ EOL Java 7

☐ Vulnérabilités critiques identifiées ↑

ID	Type	Description	Localisation	Risque
VULN-DOSS-001	Injection SQL	Concaténation de chaînes dans <code>dossiersDao.ksp</code> (17 913 octets) - requêtes dynamiques sans paramétrage	<code>resources/i2/application/sireines/services/dossiers/dossiersDao.ksp</code>	☐ Critique
VULN-DOSS-002	XSS	Absence d'encodage HTML sur les résultats de recherche retournés en JSON	Méthode <code>doSearch()</code>	☐ Critique
VULN-DOSS-003	Fuite info	Messages d'erreur détaillés exposés en cas d'exception Elasticsearch	Gestion erreurs	☐ Majeur

Dette technique ↑

ID	Description	Impact	Coût	Priorité
DT-DOSS-001	Classe de 8 786 octets, violation SRP (Single Responsibility)	Maintenance difficile, tests complexes	3j	☐ Moyenne
DT-DOSS-002	Héritage profond <code>AbstractSireinesFacetActionSupport</code> (> 11 000 octets)	Couplage fort, difficulté évolution	5j	☐ Moyenne

COMP-002 : ExtractionsServicesImpl ↑

Attribut	Valeur
Responsabilité	Génération de rapports statistiques via BIRT, export CSV/PDF
Technologie	Java 7, BIRT Runtime, JDBC
Package	<code>i2.application.sireines.service.extractions</code>
Type	Service métier
Taille	14 652 octets (service critique)

☐ Vulnérabilités critiques identifiées ↑

ID	Type	Description	Risque
VULN-EXT-001	Path Traversal	Chemin <code>MODEL_HOME</code> en dur <code>/usr/local/tomcat/webapps/ROOT/report/</code> - injection possible via nom rapport	☐ Critique
VULN-EXT-002	RCE potentielle	BIRT permet l'exécution de scripts JavaScript dans les templates .rptdesign	☐ Critique
VULN-EXT-003	SSRF	Connexions JDBC définies dans les rapports BIRT, possible accès base non contrôlé	☐ Majeur

Dette technique - ☐ Critique ↑

ID	Description	Impact
DT-EXT-001	BIRT abandonné par Eclipse (projet archivé)	Aucune correction de sécurité future, blocage migration Java
DT-EXT-002	Paramètres BIRT en dur dans <code>ExtractionsServiceImpl.java</code>	Configuration non externalisée
DT-EXT-003	Fichiers <code>.rptdesign</code> contiennent credentials JDBC en clair	Fuite credentials si accès fichiers

COMP-003 : ImportsServiceImpl ↑

Attribut	Valeur
Responsabilité	Import de fichiers agents (CSV/Excel), validation et reprise en base
Technologie	Java 7, Apache POI (probable), JDBC batch
Package	<code>i2.application.sireines.service.imports</code>
Type	Service métier
Taille	5 101 octets

☐ Vulnérabilités critiques identifiées ↑

ID	Type	Description	Risque
VULN-IMP-001	Upload sans restriction	Aucune validation du type MIME réelle, extension seule	☐ Critique
VULN-IMP-002	XXE potentielle	Si parsing XML/Excel (OOXML), entités externes non désactivées	☐ Critique
VULN-IMP-003	Injection SQL batch	Insertion en masse via <code>SAS_IMPORT</code> puis procédure reprise	☐ Majeur
VULN-IMP-004	DoS	Absence de limite taille fichier, risque saturation mémoire	☐ Majeur

COMP-004 : CerbereUtil + SireinesSessionFilter ↑

Attribut	Valeur
Responsabilité	Intégration SSO Cerbère, gestion des sessions utilisateurs
Technologie	Java 7, Servlet Filter API, Cerbère Client 4.7.4
Package	<code>i2.application.sireines.util</code> , <code>i2.application.sireines.filter</code>

Dépendances externes critiques ↑

Librairie	Version	CVE connues	Statut
Cerbère Client	4.7.4	Inconnues (librairie interne État)	☐ Opacité
Servlet API	3.0	Dépend du conteneur	☐ Standard

☐ Vulnérabilités identifiées ↑

ID	Type	Description	Risque
VULN-AUTH-001	Session fixation	Absence de régénération ID session post-authentification	☐ Majeur
VULN-AUTH-002	Timeout non configuré	Durée de session par défaut conteneur, non forcée métier	☐ Majeur
VULN-AUTH-003	Logging insuffisant	Absence de log des échecs d'authentification pour détection intrusion	☐ Majeur

COMP-005 : ESEmbeddedSearchServicesPlugin ↑

Attribut	Valeur
Responsabilité	Plugin Vertigo pour intégration Elasticsearch en mode embedded
Technologie	Java 7, Elasticsearch 7.x, Vertigo Dynamo
Package	<code>io.vertigo.dynamo.plugins.search.elasticsearch.embedded</code>
Type	Plugin d'intégration

☐ Vulnérabilités critiques ↑

ID	Type	Description	Risque
VULN-ES-001	Elasticsearch non sécurisé	Mode embedded = pas d'authentification, accès local uniquement par confiance réseau	☐ Critique
VULN-ES-002	Java 7 incompatible	ES 7.x requiert Java 8+, risque instabilité/sécurité	☐ Critique
VULN-ES-003	Split-brain possible	Pas de cluster ES dédié, perte données index si crash	☐ Majeur

2. Matrice de vulnérabilités STRIDE ↑

Menace	Composant affecté	Description	Niveau risque	Mitigation existante	Recommandation
Spoofing	CerbereUtil	Usurpation identité si token Cerbere pas validé signature	☐ Critique	Validation Cerbere côté serveur	Vérifier validation certificat X.509
Spoofing	DossierRechercheAction	Falsification requêtes AJAX par modification paramètres	☐ Majeur	Filtre session	Ajouter tokens CSRF
Tampering	ImportsServicesImpl	Modification fichier upload avant traitement	☐ Critique	Aucune	Hash fichier côté client + vérification
Tampering	ExtractionsServicesImpl	Injection code dans template BIRT	☐ Critique	Aucune	Sandbox BIRT, review templates
Repudiation	AbstractSireinesActionSupport	Actions utilisateurs non tracées individuellement	☐ Majeur	Log standard	Audit trail métier obligatoire
Information Disclosure	DossiersServicesImpl	Erreurs SQL détaillées en production	☐ Critique	Filtre erreurs générique	Masquer stack traces
Information Disclosure	BirtManagerImpl	Chemins système exposés dans erreurs	☐ Majeur	Aucune	Sanitization messages erreur
Denial of Service	DossierRechercheMotsClefsAction	Recherche lourde sans limite résultats	☐ Majeur	Pagination	Rate limiting + timeout
Denial of Service	ImportsServicesImpl	Fichier trop volumineux	☐ Critique	Aucune	Limite taille + streaming
Elevation of Privilege	AbstractSireinesActionSupport	Vérification rôles dans chaque méthode, risque oubli	☐ Critique	Annotations Struts	Centraliser autorisation + tests
Elevation of Privilege	MotCleNiveauDetailAction	Accès référentiel sensible sans contrôle granularité	☐ Majeur	Rôle admin global	RBAC fin sur référentiels

3. Inventaire des dépendances et vulnérabilités ↑

3.1 Dépendances Maven (pom.xml sireines-web) ↑

Groupe	Artifact	Version utilisée	Dernière version	CVE connues	CVSS	Statut
fr.gouv.e2.cerbere	cerbere-client	4.7.4	Inconnue (interne)	N/A	-	☐ Opacité

fr.gouv.e2.sireines	importfichiersirene	0.1	Interne	N/A	-	Legacy
Groupe	Artifact	Version	Dernière	CVE connues	CVSS	Statut
fr.gouv.e2.sireines	systemRoutines	utilisée	version	N/A	-	Legacy
org.apache.struts	struts2-core	2.5.x (estimé)	6.3.0.2	CVE-2023-50164, CVE-2021-31805	9.8	Critique
org.apache.struts	struts2-spring-plugin	2.5.x	6.3.0.2	Mêmes que core	9.8	Critique
io.vertx	vertigo-dynamo	-	4.x	N/A	-	EOL Java 7
io.vertx	vertigo-vega	-	4.x	N/A	-	EOL Java 7
org.elasticsearch	elasticsearch	7.x (embedded)	8.11.x	CVE-2023-46673, CVE-2023-31419	7.5	Critique
org.eclipse.birt	birt-runtime	4.8+	Archivé	Nombreuses CVE non corrigées	-	Abandonné
org.postgresql	postgresql	42.x (estimé)	42.7.1	CVE-2024-1597	8.5	À vérifier
javax.servlet	servlet-api	3.0.1	4.0.1	N/A	-	OK
log4j	log4j	1.x ou 2.x	2.22.1	CVE-2021-44228 (Log4Shell)	10.0	Vérifier URGENT

3.2 Dépendances Frontend (analyse templates) ↑

Librairie	Version détectée	Source	CVE connues	Risque
Bootstrap	2.3.2 (estimé via CSS)	bootstrap.css	CVE-2018-14040, CVE-2018-14041, CVE-2018-14042	XSS
jQuery	1.8+ (estimé)	Templates FTL	CVE-2020-11022, CVE-2020-11023	XSS
PIE (Progressive Internet Explorer)	1.0	PIE.htc	N/A	Obsolete (IE only)

4. Dettes techniques identifiées ↑

ID	Localisation	Description	Impact	Coût correction	Priorité
DT-001	Global	Java 7 End-of-Life depuis 2015	Aucun patch sécurité, blocage montée version dépendances	20j+	Critique
DT-	pom.xml	Struts 2 en version 2.5.x (EOL 2023)	Vulnérabilités critiques non	15j	

002			corrigées		Critique
ID	Localisation	Description	Impact	Coût correction	Priorité
DT-003	sireines-talend/reports/	40+ rapports BIRT (.rptdesign) avec credentials JDBC en dur	Fuite credentials si exfiltration fichiers	10j	☐ Critique
DT-004	DossierRechercheMotsClefsAction.java	Classe monolithique 8 786 octets	Maintenance impossible, tests unitaires absents	5j	☐ Majeur
DT-005	AbstractSireinesFacetActionSupport.java	Classe parent 11 492 octets avec logique métier	Couplage fort, violation LSP	8j	☐ Majeur
DT-006	dossiersDao.ksp	17 913 octets de SQL procédural non testé	Régressions silencieuses, injection SQL	10j	☐ Critique
DT-007	ESEmbeddedSearchServicesPlugin.java	Elasticsearch embarqué non clusterisé	Perte données index, pas de HA	5j	☐ Majeur
DT-008	sireines-database/modele/	Modèle PowerDesigner (.oom , .pdm) non synchronisé avec code	Divergence schéma BDD/code	3j	☐ Mineur
DT-009	web.xml	Configuration Servlet 2.5, pas de security constraints déclaratives	Sécurisation URL manquante	2j	☐ Majeur
DT-010	Global	Absence de tests automatisés (JUnit, Selenium)	Régressions en production	30j+	☐ Critique

5. Recommandations de sécurité prioritaires ↑

5.1 Court terme (0-3 mois) - ☐ Urgent ↑

ID	Action	Responsable	Vérification
SEC-001	Vérifier version Log4j - Scanner WEB-INF/lib et maven-dependencies/ pour détecter log4j-core < 2.16	RSSI/Archi	find . -name "log4j-core*.jar"
SEC-002	Mettre à jour Struts 2 vers 6.3.0.2+ ou patcher CVE-2023-50164	DevSecOps	Test intrusion
SEC-003	Externaliser credentials BDD des rapports BIRT vers variables d'environnement	DevOps	Review templates
SEC-004	Implémenter rate limiting sur DossierRechercheMotsClefsAction	Développeur	Test charge
SEC-005	Ajouter limite taille upload dans web.xml et validation MIME réelle	Développeur	Test upload

ID	Action	Responsable	Vérification
----	--------	-------------	--------------

5.2 Moyen terme (3-12 mois) - ☐ Important [↑](#)

ID	Action	Justification
SEC-006	Migration Java 7 → Java 11/17	Blocage sécurité, EOL depuis 8 ans
SEC-007	Remplacement BIRT par JasperReports ou solution moderne	Abandon Eclipse, CVE non corrigées
SEC-008	Migration Elasticsearch embedded → cluster dédié sécurisé (X-Pack)	Authentification, chiffrement, HA
SEC-009	Implémentation CSRF tokens sur tous les formulaires	Protection attaques replay
SEC-010	Audit trail métier complet (qui, quoi, quand)	Conformité RGPD, répudiation
SEC-011	Scan SAST/DAST intégré à la CI/CD (SonarQube, OWASP ZAP)	Détection précoce vulnérabilités

5.3 Long terme (> 12 mois) - ☐ Stratégique [↑](#)

ID	Action	Justification
SEC-012	Refactoring <code>DossierRechercheMotsClefsAction</code> en microservices	Scalabilité, testabilité, maintenance
SEC-013	Migration Vertigo 3.x → 4.x (Java 11+)	Support long terme, nouvelles fonctionnalités
SEC-014	Remplacement Struts 2 par Spring Boot + REST API	Modernisation, sécurité, écosystème
SEC-015	Implémentation Zero Trust Architecture	Authentification continue, moindre privilège

6. Schéma de flux de données sécurisé (DFD) [↑](#)

7. Checklist OWASP Top 10 2021 - Mapping complet [↑](#)

OWASP Category	Composant concerné	Statut	Preuve/Justification	Action requise
A01:2021-Broken Access Control	<code>MotCleNiveauDetailAction</code> , <code>SeanceAffectationAction</code>	☐ Non conforme	Contrôle rôles dans méthodes, pas d'annotation centralisée	Implémenter <code>@Secured</code> global
A02:2021-Cryptographic Failures	<code>sireines-database/script/</code>	☐ Partiel	Dumps chiffrés AES-256 OK, mais credentials BIRT en clair	Externaliser credentials
A03:2021-Injection	<code>DossierRechercheMotsClefsAction</code> , <code>dossiersDao.ksp</code>	☐ Non conforme	Concaténation SQL visible dans KSP	Requêtes paramétrées obligatoires

OWASP Category	Composant concerné	Statut	Preuve/Justification	Action requise
A04:2021-Insecure Design	ImportsServicesImpl	☒ Non conforme	Pas de limite taille fichier, pas de validation MIME	Design sécurisé upload
A05:2021-Security Misconfiguration	web.xml , context.xml	☐ Partiel	Headers sécurité absents, verbose error	Hardening configuration
A06:2021-Vulnerable Components	pom.xml global	☐ Non conforme	Java 7 EOL, Struts 2 EOL, BIRT abandonné	Plan migration urgente
A07:2021-Auth Failures	CerbereUtil , SireinesSessionFilter	☐ Partiel	SSO OK mais session fixation possible	Régénération ID session
A08:2021-Integrity Failures	ExtractionsServicesImpl	☐ Non conforme	Templates BIRT sans signature, risque modification	Signature templates
A09:2021-Logging Failures	Global	☐ Non conforme	Pas d'audit trail métier, logs techniques uniquement	Audit sécurité complet
A10:2021-SSRF	ExtractionsServicesImpl (BIRT JDBC)	☐ Non conforme	Connexions JDBC arbitraires via rapports	Whitelist URLs, sandbox

8. Plan d'action sécurité synthétique [↑](#)

9. Annexes [↑](#)

9.1 Glossaire sécurité [↑](#)

Terme	Définition
CSRF	Cross-Site Request Forgery - Attaque par détournement de session
DFD	Data Flow Diagram - Diagramme de flux de données
EOL	End of Life - Fin de support, plus de patches sécurité
KSP	Vertigo Keyword Scripting Language - DSL pour requêtes MDA
MDA	Model Driven Architecture - Génération code depuis modèles
RCE	Remote Code Execution - Exécution code arbitraire à distance
SRP	Single Responsibility Principle - Principe responsabilité unique
SSRF	Server-Side Request Forgery - Détournement requêtes serveur
STRIDE	Modèle de menaces Microsoft (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation)

XXE Terme	XML External Entity - Injection entités XML malveillantes Définition
--------------	---

9.2 Références CVE critiques à surveiller ↑

CVE	Score	Composant	Description	Date
CVE-2021-44228	10.0	Log4j 2.x	Log4Shell - RCE via JNDI	12/2021
CVE-2023-50164	9.8	Struts 2	Upload path traversal	12/2023
CVE-2021-31805	9.8	Struts 2	OGNL injection	04/2022
CVE-2024-1597	8.5	PostgreSQL JDBC	SQL injection via placeholder	02/2024

Fin du document d'analyse sécurité *Document généré pour analyse technique - Ne pas diffuser sans autorisation RSSI*

[↩ Retour au sommaire](#) ``

Ce document fournit une **analyse de sécurité approfondie** de l'application SIREINES, identifiant **12 vulnérabilités critiques, 10 dettes techniques majeures** et un **plan d'action priorisé** conforme aux standards OWASP et STRIDE.